Task – 4

By Akshai S

Intro

This assessment documents a hands-on security evaluation of the ERULNX16 virtual machine provided for the OWASP bootcamp. Using network scanning and basic credential testing, we identified multiple exposed services (FTP, SSH, HTTP and others) and confirmed default credentials permitted access. The findings show an insecure lab configuration with outdated services and weak authentication that could be exploited in a real environment; recommended mitigations are provided.

1. What i did

1. Imported and booted the ERULNX16 OVA inside VirtualBox and opened the VM console .
2. Confirmed the VM was up and reachable at IP 10.0.2.15.
3. Performed a full TCP port/service scan with nmap to identify running services and versions.
4. Tested service access using default lab credentials (vagrant) for FTP and SSH.
5. Recorded outputs and screenshots for evidence.

Key commands used :

port/service discovery

Nmap 10.0.2.15

quick FTP test
ftp 10.0.2.15

login: vagrant / vagrant

SSH login
ssh vagrant@10.0.2.15

password: vagrant

2. What we found (bugs / issues & severity)

	Service (port)	Finding / Why it's a problem	Severity
1	FTP — port 21	Allows login with default vagrant account. ProFTPD 1.3.5 is old, known risky modules exist in legacy builds. Exposed FTP can leak configs/backups.	**Medium**
2	SSH — port 22	SSH accepts default vagrant credentials. Default weak creds give shell access a direct foothold.	**Medium**
3	HTTP — port 80	Web servers running, potential for exposed webapps, config files, backups, upload points. Requires web enumeration.	**Medium**
4	MySQL — port 33	DB service open (unauthenticated to scanner):may contain credentials/data or be used for pivot.	**Medium**

3. Recommended fixes

1. **Remove default account or change password** :change `vagrant` password and/or disable it. Enforce unique strong creds.
2. **Disable or secure FTP** :prefer (SSH subsystem) over plain FTP; remove or update ProFTPD and disable unsafe modules.
3. **Harden SSH** : disable password auth where possible, enable key-only login, and enable fail2ban.
4. **Harden web apps** : remove backups/config files from webroot, restrict file permissions, and update Jetty/Apache versions.
5. **Close unnecessary services** :stop MySQL/IRC/NetBIOS if not required for the app. Reduce attack surface.
6. **Patch & update** : update OS and all server packages to supported releases.

Conclusion:

This lab exercise gave a real-world feel of how insecure services and default credentials can expose a system. By running network scans and testing service access, we confirmed several open ports and successfully logged in using default SSH and FTP credentials. These weaknesses highlight the importance of hardening systems, disabling unused services, and changing default passwords before deployment. Overall, this challenge improved our practical skills in scanning, enumeration, and basic exploitation, reinforcing why proactive security checks matter in real environments.

```
Ubuntu 14.04 LTS ubuntu tty1

ubuntu login: vagrant
Password:
Last login: Thu Oct 30 14:35:51 UTC 2025 from localhost on pts/2
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

vagrant@ubuntu:~$ VBoxGuestAdditions.iso
```

```
21/tcp   open  ftp
22/tcp   open  ssh
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
631/tcp  open  ipp
3306/tcp open  mysql
6667/tcp open  irc
8080/tcp open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 0.14 seconds
vagrant@ubuntu:~$ VBoxGuestAdditions.iso VBoxGuestAdditions.iso VBoxGuestAdditio
ns.iso VBoxGuestAdditions.iso VBoxGuestAdditions.iso VBoxGuestAdditions.iso VBox
GuestAdditions.iso VBoxGuestAdditions.iso VBoxGuestAdditions.iso VBoxGuestAdditi
ons.iso VBoxGuestAdditions.iso VBoxGuestAdditions.iso VBoxGuestAdditions.iso VBo
```

nmap output listing open ports and services.

```
vagrant@ubuntu:~$ ftp 10.0.2.15
Connected to 10.0.2.15.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.15]
Name (10.0.2.15:vagrant): vagrant
331 Password required for vagrant
Password:
230 User vagrant logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

```
VBoxGuestAdditions.iso: command not found
vagrant@ubuntu:~$ ssh vagrant10.0.2.15
ssh: Could not resolve hostname vagrant10.0.2.15: Name or service not known
vagrant@ubuntu:~$ ssh vagrant@10.0.2.15
vagrant@10.0.2.15's password:
Welcome to Ubuntu 14.04 LTS (GNU/Linux 3.13.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com/
New release '16.04.7 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Thu Oct 30 14:55:34 2025 from ubuntu
```